Jr.Pen 3.3. Protocols and Servers

Protocols and Servers

1 - Introduction

These protocols form the foundation of how you browse the web, transfer files, and send and receive email. Each protocol task is designed to show what happens beneath the surface, which is usually hidden by a GUI (Graphical User Interface).

2 - Telnet

The Telnet protocol is an application-layer protocol used to connect to a virtual terminal of another computer. Using Telnet, a user can log into a remote machine and access its terminal (console) to run programs, start batch processes, and perform system administration tasks remotely. The Telnet protocol is relatively simple. When a user connects, they are asked for a username and password. Upon correct authentication, the user gains access to the remote system's terminal. However, all communication between the Telnet client and the Telnet server is unencrypted, making it an easy target for attackers. However, it has been almost entirely replaced by SSH (Secure Shell) for interactive remote access. However, you may still encounter it in:

- Legacy systems and older network equipment (routers, switches, industrial controllers)
- Embedded devices and IoT equipment with limited resources
- Internal networks where security was never prioritised
- Misconfigured systems where Telnet was enabled but never disabled

During penetration tests, finding an open Telnet port (23) is often a significant finding because it indicates either a legacy system or a security misconfiguration.

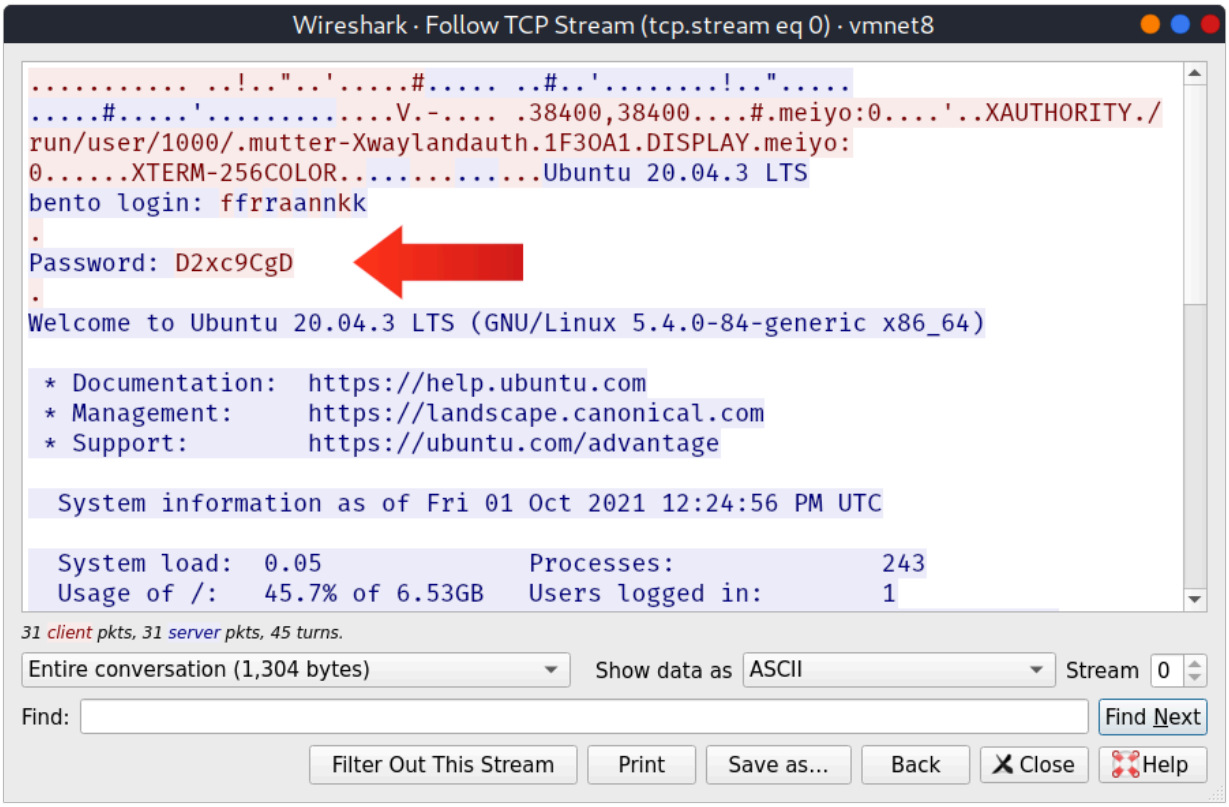
While Telnet servers are rare, the Telnet client remains useful as a simple tool for connecting to any TCP port and manually interacting with text-based protocols. For example, you can use `telnet target 80` to connect to a web server and type HTTP commands manually.

A Telnet server listens for incoming connections on port 23 using the Telnet protocol. The following terminal output is illustrative and was captured from a separate environment.

```
pentester@TryHackMe$ telnet MACHINE_IP
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
Ubuntu 20.04.3 LTS
```

```
bento login: frank
Password: D2xc9CgD
Welcome to Ubuntu 20.04.3 LTS (GNU/Linux 5.4.0-84-generic x86_64)
```

Although Telnet provides access to the remote system's terminal quickly, it is not a reliable protocol for remote administration because all data is sent in cleartext. In the figure below, the traffic generated by Telnet has been captured, and it was trivial to find the password. The figure shows the ASCII data exchanged between the client and the remote system. The text in red is what the client sends, while the text in blue is what the remote system sends back. Notice how the username was echoed back to display in the terminal; however, the password was not. In other words, if someone were watching the screen, they would not see the password characters. However, this visual protection is meaningless because the password still travels across the network in cleartext.



Telnet is no longer considered a secure option. Anyone capturing your network traffic can discover your usernames and passwords, which would grant them access to the remote system. This includes:

- Attackers on the same network segment
- Anyone who has compromised a router or switch along the path

- Malicious insiders with network access
- Anyone performing a successful man-in-the-middle attack

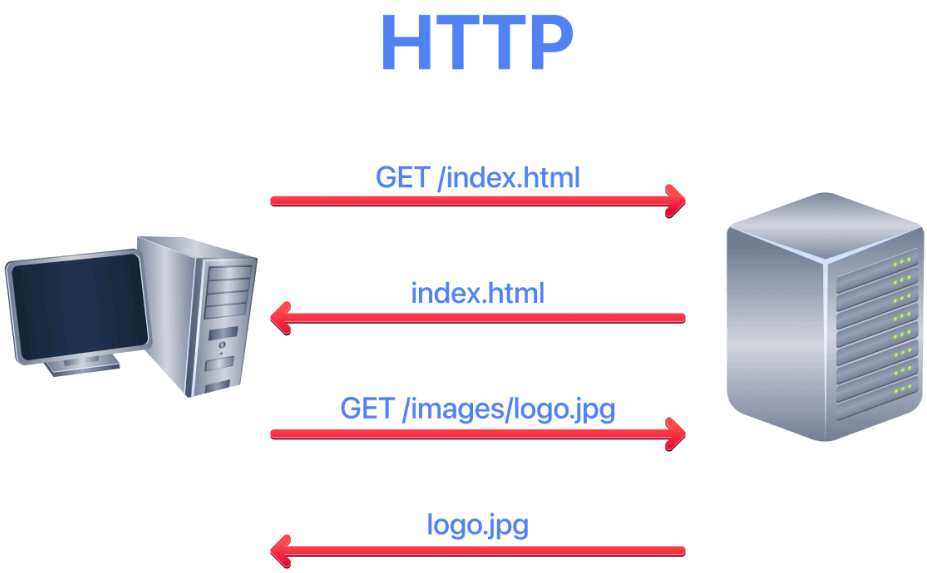
The secure alternative is SSH (Secure Shell), which encrypts all traffic, including credentials. SSH has been the standard for remote command-line access for over two decades.

Answer the questions below

> To which port will the `telnet` command with the default parameters try to connect? 23

3 - Hypertext Transfer Protocol (HTTP)

Hypertext Transfer Protocol (HTTP) is the protocol used to transfer web pages. Your web browser connects to the web server and uses HTTP to request HTML pages, images, and other files. It also submits forms and uploads various files. Any time you browse the World Wide Web (WWW), you are using the HTTP protocol. The image below shows a client requesting the HTML page `index.html`, which the web server provides. The client then requests an image, `logo.jpg`, and the web server sends it.



HTTP sends and receives data as cleartext (not encrypted). This means anyone with access to the network traffic can read the content being transferred, including sensitive information like login credentials and personal data. Today, the vast majority of websites use HTTPS (HTTP Secure), which wraps HTTP inside TLS encryption. Modern browsers mark plain HTTP sites as "Not Secure", and some features (like geolocation and camera access) are blocked entirely on non-HTTPS sites. However, understanding how HTTP works is still essential because:

- The HTTP commands and structure are identical whether using HTTP or HTTPS.
- You will encounter HTTP during internal penetration tests and on legacy systems.
- Understanding the protocol helps you identify and exploit web vulnerabilities.
- Tools like Burp Suite decrypt HTTPS traffic for analysis, showing you raw HTTP.

The Telnet client is used because Telnet is a simple protocol that uses cleartext for communication. The steps are as follows:

1. Connect to port 80 using `telnet MACHINE_IP 80`.
2. Type `GET /index.html HTTP/1.1` to retrieve the page `index.html`, or `GET / HTTP/1.1` to retrieve the default page.
3. Provide a value for the host header, such as `host: telnet`, and press the Enter/Return key **twice**.

```
pentester@TryHackMe$ telnet MACHINE_IP 80
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
GET /index.html HTTP/1.1
host: telnet

HTTP/1.1 200 OK
Server: nginx/1.18.0 (Ubuntu)
Date: Wed, 15 Sep 2021 08:56:20 GMT
Content-Type: text/html
Content-Length: 234
Last-Modified: Wed, 15 Sep 2021 08:53:59 GMT
Connection: keep-alive
ETag: "6141b4a7-ea"
Accept-Ranges: bytes

<!DOCTYPE html>
<html lang="en">
<head>
  <title>Welcome to my Web Server</title>
  <meta charset="UTF-8" />
  <meta name="viewport" content="width=device-width,initial-scale=1" />
</head>
<body>
  <h1>Coming Soon</h1>
```

```
</body>
</html>
```

The `Server: nginx/1.18.0 (Ubuntu)` header reveals both the web server software and version, as well as the operating system. This information is valuable during reconnaissance because:

- Specific versions may have known vulnerabilities you can research.
- The OS information helps tailor further attacks.
- Even knowing the web server software narrows down potential attack vectors.

Security-conscious administrators often configure their servers to suppress or obscure this information. During a penetration test, finding detailed version information in headers is worth noting.

An HTTP server (web server) and an HTTP client (web browser) are required to use the HTTP protocol. The web server "serves" a specific set of files to the requesting web browser. Popular choices for HTTP servers include:

- **Nginx** has become the most widely used web server on the internet, known for its performance and efficiency in handling concurrent connections. It is free and open-source.
- **Apache** remains extremely popular and powers a large portion of websites. It is highly configurable with a vast ecosystem of modules. It is also free and open-source.
- **Internet Information Services (IIS)** is Microsoft's web server, commonly found in Windows enterprise environments. It requires a Windows Server licence.

Other notable web servers include **LiteSpeed**, **Caddy** (which has automatic HTTPS built in), and **Node.js** for JavaScript-based applications.

HTTP Protocol Versions: The example above uses HTTP/1.1, which has been the workhorse of the web for decades. However, newer versions exist.

HTTP/2 introduced multiplexing (multiple requests over a single connection), header compression, and server push. It is binary rather than text-based, making it harder to manually interact with using Telnet.

HTTP/3 uses QUIC (built on UDP) instead of TCP, offering improved performance, especially on unreliable networks. It is increasingly common on major websites.

> Launch the attached VM. From the AttackBox terminal, connect using Telnet to `MACHINE_IP 80` and retrieve the file `flag.thm`. What does it contain?

THM{e3eb0a1df437f3f97a64aca5952c8ea0}

4 - File Transfer Protocol (FTP)

File Transfer Protocol (FTP) was developed to make the transfer of files between different computers with different systems efficient. It was one of the earliest protocols designed for the internet and remains in use today, though it has largely been replaced by secure alternatives for most purposes.

FTP sends credentials and data in cleartext, making it insecure for transferring sensitive information. For this reason, FTP has been replaced in most environments by:

- **SFTP (SSH File Transfer Protocol)** SSH runs over FTP on port 22 and encrypts all traffic. This is the most common replacement for .
- **FTPS (FTP Secure)** TLS adds encryption to the FTP protocol on port 990 (implicit TLS) or uses STARTTLS on port 21.
- **SCP (Secure Copy Protocol)** also runs over SSH, though it is being deprecated in favour of SFTP.

However, you will still encounter plain FTP in:

- Legacy systems and older applications that have not been updated
- Anonymous FTP servers for public file distribution
- Internal networks where encryption was never implemented
- Embedded devices and network equipment with limited capabilities
- Misconfigured servers where secure alternatives were not enabled

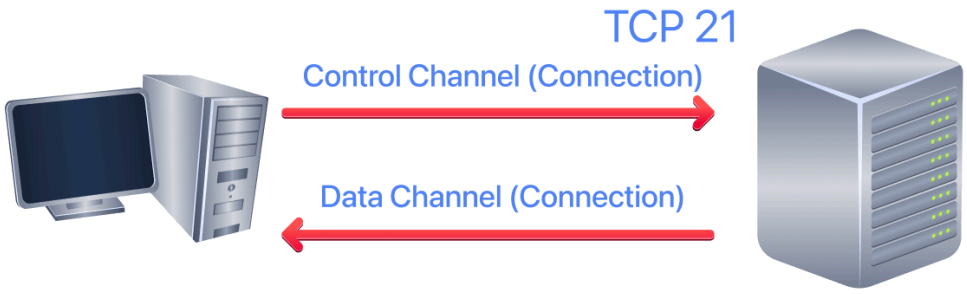
During penetration tests, finding an FTP server (especially one allowing anonymous login) is a common and significant finding.

Manually Interacting with FTP: FTP sends and receives data as cleartext, so you can use Telnet (or Netcat) to communicate with an FTP server and act as an FTP client.

```
pentester@TryHackMe$ telnet MACHINE_IP 21
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
220 (vsFTPd 3.0.3)
USER frank
331 Please specify the password.
PASS D2xc9CgD
230 Login successful.
```

How FTP File Transfer Works: The image below shows how an actual file transfer is conducted using FTP. The FTP client initiates a connection to an FTP server, which listens on port 21 by default. All commands are sent over the control channel. Once the client requests a file, another TCP connection is established between them for the data transfer. This dual-connection architecture is one reason FTP can be problematic with firewalls.

FTP



Because of the dual-connection architecture, an actual FTP client is needed to download files. After logging in successfully, you get the FTP prompt, `ftp>`, to execute various FTP commands. In the example below, `ls` lists the files, `ascii` switches to ASCII mode since the target is a text file (not binary), and `get FILENAME` initiates the file transfer by establishing a separate data channel.

```
pentester@TryHackMe$ ftp MACHINE_IP
Connected to MACHINE_IP.
220 (vsFTPd 3.0.3)
Name: frank
331 Please specify the password.
Password: D2xc9CgD
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
227 Entering Passive Mode (10,20,30,148,201,180).
150 Here comes the directory listing.
-rw-rw-r--    1 1001     1001         4006 Sep 15 10:27 README.txt
226 Directory send OK.
ftp> ascii
200 Switching to ASCII mode.
ftp> get README.txt
local: README.txt remote: README.txt
227 Entering Passive Mode (10,10,0,148,125,55).
150 Opening BINARY mode data connection for README.txt (4006 bytes).
WARNING! 9 bare linefeeds received in ASCII mode
File may not have transferred correctly.
```

```
226 Transfer complete.
4006 bytes received in 0.000269 secs (14892.19 Kbytes/sec)
ftp> exit
221 Goodbye.
```

Security Implications: Because FTP sends login credentials, commands, and files in cleartext, FTP traffic is an easy target for attackers. Anyone capturing network traffic can see usernames and passwords, file contents being transferred, directory listings revealing server structure, and the commands showing what actions users are performing.

If you must use FTP, restrict it to isolated networks or use FTPS with TLS encryption. For most purposes, SFTP over SSH is the recommended alternative.

Questions: For this task, use the FTP client on the AttackBox to connect to MACHINE_IP. The credentials are `frank` / `D2xc9CgD`.

> Using an FTP client, connect to the VM and try to recover the flag file. What is the flag?

- Username: frank
- Password: D2xc9CgD

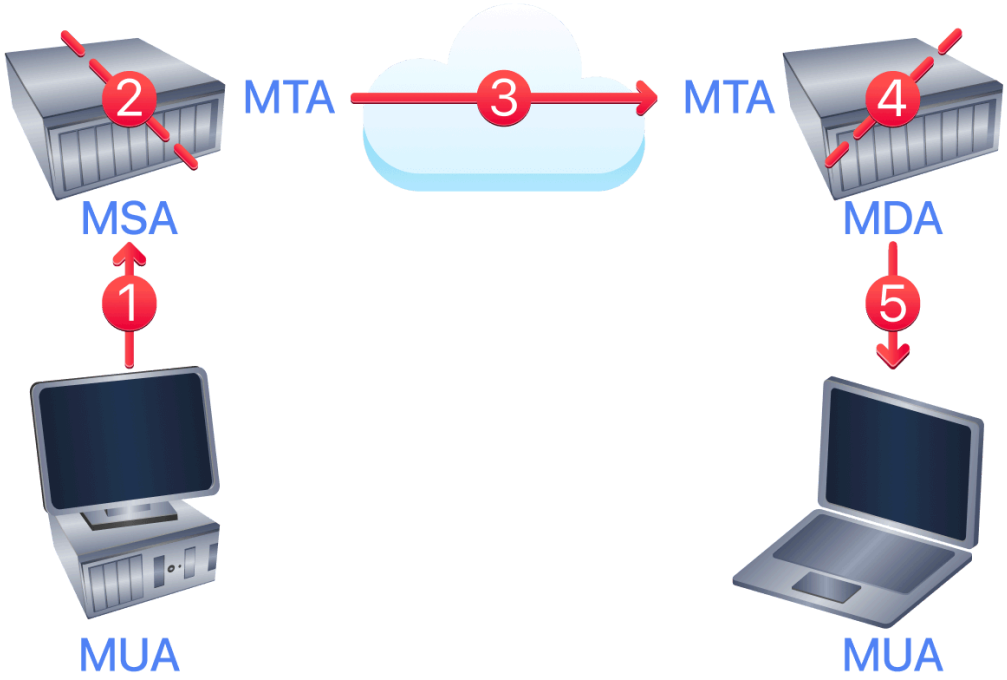
THM{364db6ad0e3ddfe7bf0b1870fb06fbdf}

5 - Simple Mail Transfer Protocol (SMTP)

Email is one of the most used services on the Internet. There are various configurations for email servers; for instance, you may set up an email system to allow local users to exchange emails with each other with no access to the Internet. However, this task considers the more general setup where different email servers connect over the Internet.

Email Delivery Components: Email delivery over the Internet requires the following components:

1. **Mail User Agent (MUA)**: The email client (e.g., Thunderbird, Outlook, a webmail interface).
2. **Mail Submission Agent (MSA)**: Receives mail from the MUA, checks for errors, and forwards it.
3. **Mail Transfer Agent (MTA)**: Routes and delivers mail between servers.
4. **Mail Delivery Agent (MDA)**: Stores the email in the recipient's mailbox for retrieval.



In the same way you follow a protocol to communicate with an HTTP server, you rely on email protocols to talk with an MTA and an MDA. The protocols are:

1. **Simple Mail Transfer Protocol (SMTP)** for sending email
2. **Post Office Protocol version 3 (POP3)** or **Internet Message Access Protocol (IMAP)** for receiving email

Simple Mail Transfer Protocol (SMTP) is used to communicate with an MTA server. The original SMTP uses cleartext, where all commands are sent without encryption. However, modern email infrastructure uses several ports with different security models:

```
pentester@TryHackMe$ telnet MACHINE_IP 25
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
220 bento.localdomain ESMTP Postfix (Ubuntu)
helo telnet
250 bento.localdomain
mail from:
250 2.1.0 Ok
rcpt to:
250 2.1.5 Ok
data
354 End data with .
```

```
subject: Sending email with Telnet
Hello Frank,
I am just writing to say hi!
.
250 2.0.0 Ok: queued as C3E7F45F06
quit
221 2.0.0 Bye
Connection closed by foreign host.
```

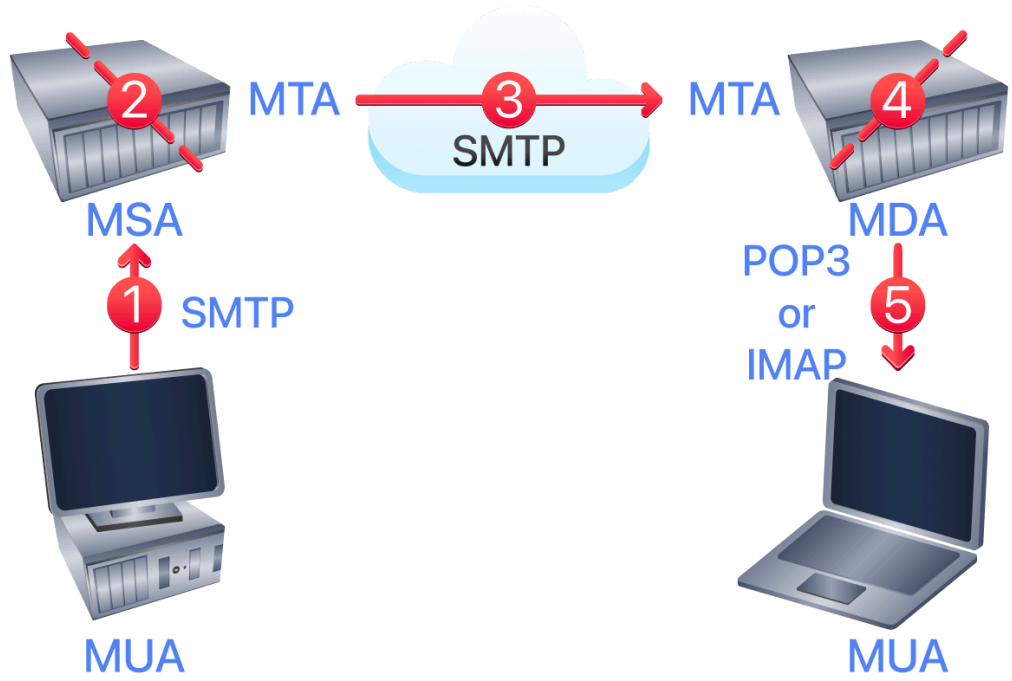
Answer the questions below

> Using the AttackBox terminal, connect to the SMTP port of the target VM. What is the flag that you can get?

THM{5b31ddfc0c11d81eba776e983c35e9b5}

6 - Post Office Protocol 3 (POP3)

Post Office Protocol version 3 (POP3) is a protocol used to download email messages from a Mail Delivery Agent (MDA) server, as shown in the figure below. The mail client connects to the POP3 server, authenticates, downloads the new email messages, and then (optionally) deletes them from the server.



```
pentester@TryHackMe$ telnet MACHINE_IP 110
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
+OK MACHINE_IP Mail Server POP3 Wed, 15 Sep 2021 11:05:34 +0300
USER frank
+OK frank
PASS D2xc9CgD
+OK 1 messages (179) octets
STAT
+OK 1 179
LIST
+OK 1 messages (179) octets
1 179
.
RETR 1
+OK
From: Mail Server
To: Frank
subject: Sending email with Telnet
Hello Frank,
I am just writing to say hi!
.
QUIT
+OK MACHINE_IP closing connection
Connection closed by foreign host.
```

Common POP3 Commands

Command	Description
USER username	Identifies the user
PASS password	Authenticates with the password
STAT	Returns the number of messages and the total size
LIST	Lists all messages with their sizes
RETR n	Retrieves message number n
DELE n	Marks message n for deletion
RSET	Resets (unmarks) messages marked for deletion
QUIT	Ends the session and deletes marked messages

Security Implications: From a security perspective, finding a POP3 server (especially on port 110) during a penetration test presents opportunities. Credentials sent over cleartext POP3 can be captured through network sniffing, password attacks can be conducted against POP3 authentication, and successful access to a mailbox may reveal sensitive information, credentials for other systems, or password reset links. If you capture POP3 traffic and see the `USER` and `PASS` commands, you have obtained valid credentials that might be reused on other systems.

Answer the questions below

> Connect to the VM (`MACHINE_IP`) at the POP3 port. Authenticate using the username `frank` and password `D2xc9CgD`. What is the response you get to STAT?

+OK 0 0

> How many email messages are available to download via POP3 on MACHINE_IP? 0

7 - Internet Message Access Protocol (IMAP)

Internet Message Access Protocol (IMAP) is more sophisticated than POP3. IMAP makes it possible to keep email synchronised across multiple devices (and mail clients). If you mark an email message as read when checking your email on your smartphone, the change is saved on the IMAP server (MDA) and replicated on your laptop when you synchronise your inbox. IMAP has largely replaced POP3 for most users because of how email is accessed today. People check email from their phones, laptops, tablets, and web browsers, often switching between devices throughout the day. IMAP's server-side storage model makes this seamless:

- Emails remain on the server and are accessible from any device.
- Read/unread status, folders, and flags are synchronised across all clients.
- Deleting an email on one device removes it everywhere.
- Search can be performed server-side without downloading all messages.

```
pentester@TryHackMe$ telnet MACHINE_IP 143
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
* OK [CAPABILITY IMAP4rev1 UIDPLUS CHILDREN NAMESPACE THREAD=ORDEREDSUB
JECT THREAD=REFERENCES SORT QUOTA IDLE ACL ACL2=UNION STARTTLS ENABLE U
TF8=ACCEPT] Courier-IMAP ready. Copyright 1998-2018 Double Precision, I
nc.  See COPYING for distribution information.
c1 LOGIN frank D2xc9CgD
* OK [ALERT] Filesystem notification initialization error -- contact yo
```

```
ur mail administrator (check for configuration errors with the FAM/Gami
n library)
c1 OK LOGIN Ok.
c2 LIST "" "*"
* LIST (\HasNoChildren) "." "INBOX.Trash"
```

Common IMAP Commands

Command	Description
LOGIN username password	Authenticates the user
LIST "" "*"	Lists all mailbox folders
SELECT folder	Opens a folder for read/write access
EXAMINE folder	Opens a folder for read-only access
FETCH n BODY[]	Retrieves message number n
SEARCH criteria	Searches for messages matching criteria
STORE n +FLAGS (\Seen)	Marks message n as read
LOGOUT	Ends the session

IMAP vs Webmail: Many users today access email through web interfaces (Gmail, Outlook.com, etc.) rather than dedicated mail clients. These web interfaces use HTTPS to secure the connection between the browser and the mail provider's servers. However, the underlying mail storage still uses IMAP concepts, and many users configure traditional mail clients alongside webmail access. Understanding IMAP remains relevant because enterprise environments often run their own mail servers with IMAP access, penetration testers may encounter IMAP services during assessments, mobile devices and desktop mail clients still use IMAP extensively, and compromised IMAP credentials provide deeper access than webmail in some scenarios.

Answer the questions below

> What is the default port used by IMAP? 143

8 - Conclusion

Protocol	TCP Port	Application(s)	Data Security	Secure Alternative	Secure Port
FTP	21	File Transfer	Cleartext	FTPS or SFTP	990 (FTPS), 22 (SFTP)
HTTP	80	Worldwide Web	Cleartext	HTTPS	443
IMAP	143	Email (MDA)	Cleartext	IMAPS	993
POP3	110	Email (MDA)	Cleartext	POP3S	995

Protocol	TCP Port	Application(s)	Data Security	Secure Alternative	Secure Port
SMTP	25	Email (MTA)	Cleartext	SMTPS or SMTP with STARTTLS	465 (SMTPS), 587 (Submission)
Telnet	23	Remote Access	Cleartext	SSH	22

9 - Introduction -2

Servers implementing these protocols are subject to different kinds of attacks:

1. Sniffing Attack (Network Packet Capture)
2. Man-in-the-Middle (MITM) Attack
3. Password Attack (Authentication Attack)
4. Vulnerabilities

The Modern Attack Landscape

- **Sniffing attacks** are harder on properly configured networks due to widespread TLS adoption, but they remain effective against misconfigured services, internal networks without encryption, and legacy systems.
- **MITM attacks** are mitigated by technologies like HSTS (Strict Transport Security), certificate pinning, HTTP and Certificate Transparency logs, but they can still succeed when these protections are absent or improperly implemented.
- **Password attacks** have evolved beyond simple brute force. Attackers now use credential stuffing (trying leaked username/password pairs from breaches), password spraying (trying common passwords across many accounts), and leverage massive breach databases.

10 - Sniffing Attack

A **sniffing attack** refers to using a network packet capture tool to collect information about the target. When a protocol communicates in cleartext, the data exchanged can be captured by a third party to analyse. A simple network packet capture can reveal information such as the content of private messages and login credentials if the data is not encrypted in transit.

Where Sniffing Attacks Are Still Relevant

- **Internal corporate networks** where traffic between systems may not be encrypted
- **Legacy systems** that still use cleartext protocols (older mail servers, embedded devices, industrial control systems)
- **Misconfigured services** where TLS is available but not enforced

- **IoT devices** that often use unencrypted protocols for communication
- **Wireless networks** where attackers within range can capture traffic
- **After a successful MITM attack** that downgrades or strips encryption

The command used is `sudo tcpdump port 110 -A`. The `sudo` prefix is required because packet captures require root privileges. The `port 110` filter limits captured packets to those exchanged with the POP3 server (POP3 uses port 110 by default). The `-A` flag displays the contents of captured packets in ASCII format, making cleartext credentials readable in the output.

```
pentester@TryHackMe$ sudo tcpdump port 110 -A
[...]
09:05:15.132861 IP 10.20.30.1.58386 > 10.20.30.148.pop3: Flags [P.], se
q 1:13, ack 19, win 502, options [nop,nop,TS val 423360697 ecr 39582755
30], length 12
E..@.V@.@.g.
...
......n......".............
.;....}.USER frank
```

In the terminal output above, unimportant packets have been removed for clarity. The username and password were sent in separate packets. The first packet explicitly displays `USER frank`, while the last packet reveals the password `PASS D2xc9CgD`.

The primary mitigation is adding an encryption layer on top of the network protocol. **Transport Layer Security (TLS)** has been added to HTTP, FTP, SMTP, POP3, IMAP, and many others. For remote access, Telnet has been replaced by the secure alternative Secure Shell (SSH).

Additional mitigations include:

- **Network segmentation** limits which systems can see each other's traffic by dividing the network into isolated zones.
- **Encrypted VLANs and tunnels** protect sensitive traffic even on internal networks.
- **802.1X port-based authentication** requires devices to authenticate before gaining network access, preventing unauthorised devices from connecting and sniffing traffic.
- **Zero trust architecture** is a security model that treats all network traffic as potentially hostile, encrypting all communications regardless of whether they originate inside or outside the network perimeter.
- **Monitoring for ARP spoofing** and other traffic redirection techniques helps detect sniffing attempts in progress.

> What do you need to add to the command sudo tcpdump to capture only Telnet traffic?

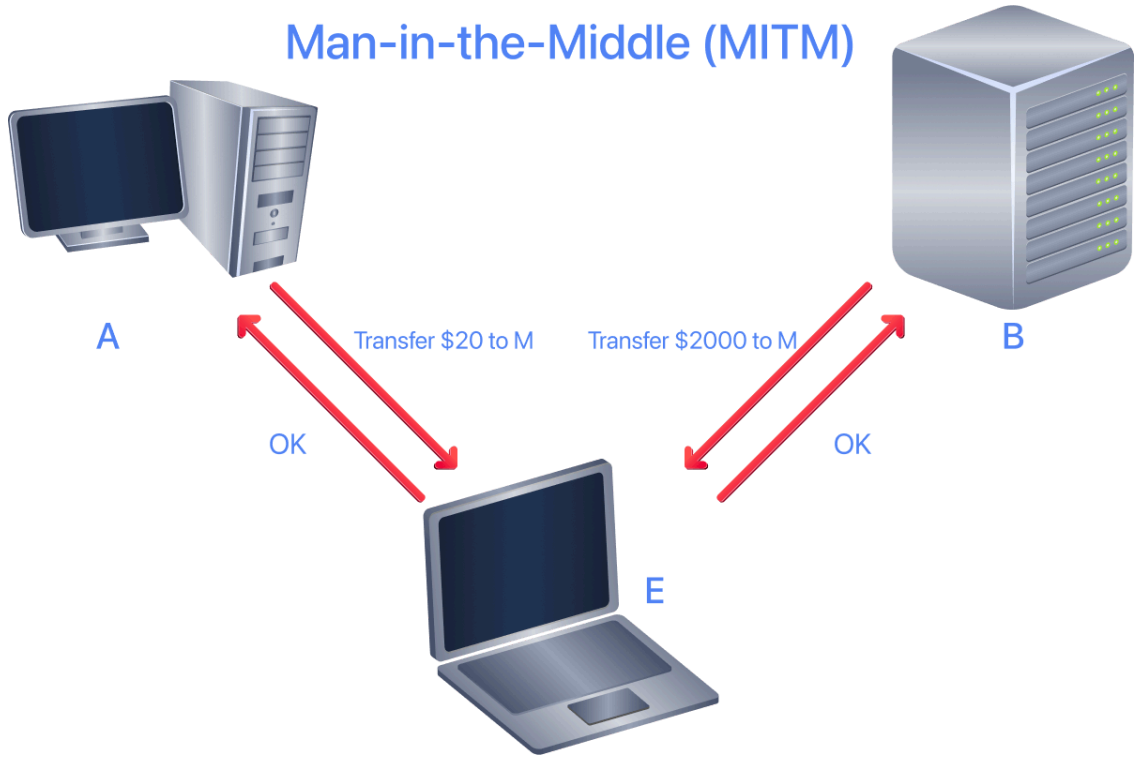
port 23

> What is the simplest display filter you can use with Wireshark to show only IMAP traffic?

imap

11 - Man-in-the-Middle (MITM) Attack

A **Man-in-the-Middle (MITM) attack** occurs when a victim (A) believes they are communicating with a legitimate destination (B) but is unknowingly communicating with an attacker (E). In the figure below, A requests the transfer of $20 to M. However, E alters this message and replaces the original value with a new one. B receives the modified message and acts on it.



This attack is relatively simple to carry out if the two parties do not confirm the authenticity and integrity of each message. In some cases, the chosen protocol does not provide secure authentication or integrity checking. Some protocols have inherent insecurities that make them susceptible to this kind of attack.

How MITM Attacks Work: For an attacker to position themselves between two communicating parties, they typically need to redirect traffic through their system. Common techniques include:

ARP Spoofing is effective on local networks. The attacker sends forged ARP (Address Resolution Protocol) messages to associate their MAC address with the IP address of the default gateway or target system. As a result, traffic intended for those systems is sent to the attacker instead.

DNS Spoofing involves providing false DNS responses to redirect victims to attacker-controlled servers. This can happen through compromised DNS servers, DNS cache poisoning, or by responding to DNS queries faster than the legitimate server.

Rogue Access Points are fake wireless access points set up by attackers. When victims connect to these networks (often named to look like legitimate networks such as `Airport_WiFi_Free`), all their traffic flows through the attacker's system.

BGP Hijacking operates at the internet routing level, where attackers announce false BGP routes to redirect traffic through their infrastructure. This is a more sophisticated attack, typically targeting specific organisations or regions.

Tools for MITM Attacks

- **Bettercap** is the modern successor to Ettercap and is actively maintained. It supports ARP spoofing, DNS spoofing, HTTP/HTTPS proxying, and has a modular architecture for various attack scenarios.
- **Ettercap**is a classic tool for MITM attacks on LANs. While still functional, Bettercap is generally preferred for modern assessments.
- **mitmproxy** is an interactive HTTPS proxy that allows inspection and modification of traffic. It is particularly useful for analysing and manipulating HTTP/HTTPS communications.
- **Responder** is designed for Windows environments and exploits name resolution protocols such as **LLMNR** (Link-Local Multicast Name Resolution) and **NBT-NS** (NetBIOS Name Service).

MITM Against Encrypted Traffic: MITM attacks can target HTTPS and other encrypted protocols through several approaches:

SSL Stripping downgrades HTTPS connections to HTTP. When a victim tries to connect to a website, the attacker intercepts the request, establishes an HTTPS connection with the legitimate server, but serves the content to the victim over unencrypted HTTP. The victim may not notice the missing padlock icon, especially if they did not explicitly type `https://`.

Fake Certificates involve the attacker presenting their own certificate and establishing separate encrypted connections with both parties. This works if the victim accepts an invalid certificate warning or if the attacker has compromised a Certificate Authority (CA).

Compromised or Rogue CAs represent a more serious threat. If an attacker controls a trusted CA (or obtains a fraudulent certificate from one), they can generate valid-looking certificates for any domain.

Modern Defences Against MITM

HTTPS Everywhere: Most websites now use HTTPS by default. Major browsers mark HTTP sites as "Not Secure", and some have begun blocking mixed content entirely.

HSTS (HTTP Strict Transport Security) tells browsers to only connect via HTTPS for a specified period. Once a browser has seen an HSTS header for a domain, it will refuse to connect over HTTP, preventing SSL stripping attacks. Many major sites are also on the **HSTS preload list**, meaning browsers ship with knowledge that these sites should only be accessed via HTTPS.

Certificate Transparency (CT) requires CAs to log all issued certificates to public, auditable logs. This makes it much harder for attackers to obtain fraudulent certificates without detection. Browsers can check these logs and reject certificates that are not properly logged.

Certificate Pinning allows applications to specify exactly which certificates or public keys are valid for their connections. This is common in mobile apps and prevents attacks even if a CA is compromised. However, it makes certificate rotation more complex.

DANE (DNS-based Authentication of Named Entities) uses DNSSEC to publish certificate information in DNS records, providing an alternative trust path that does not rely solely on the CA system.

> How many different interfaces does Ettercap offer? 3

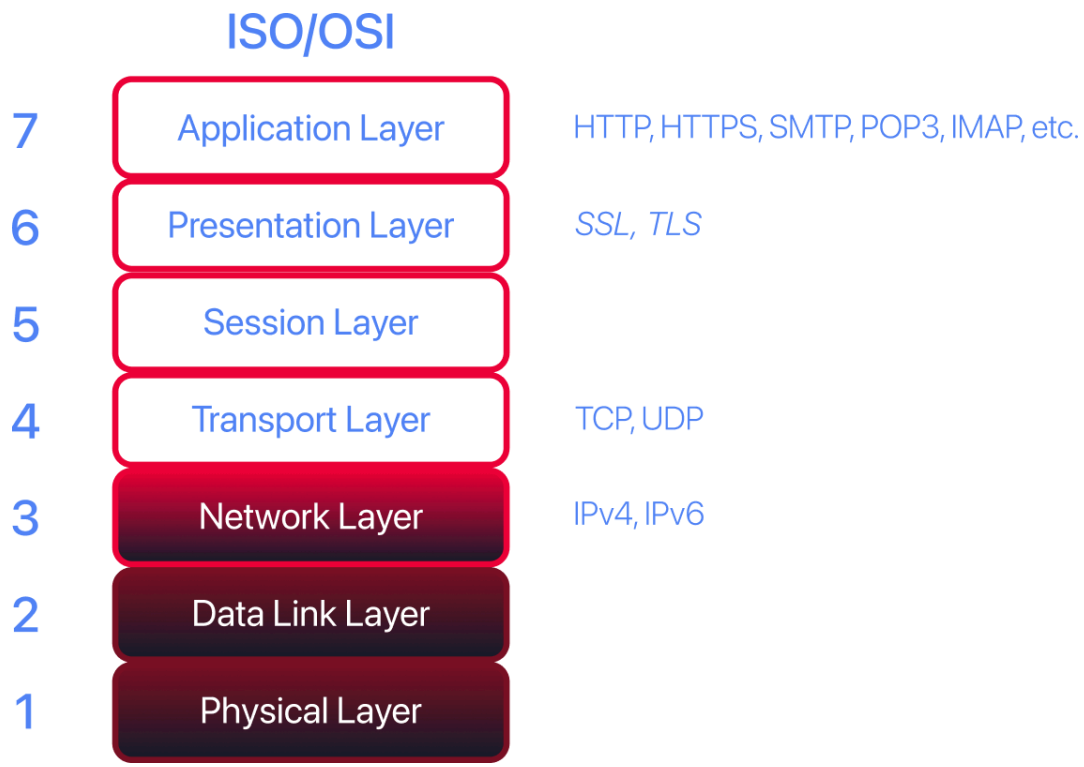
> In how many ways can you invoke Bettercap? 3

12 - Transport Layer Security (TLS)

A Brief History of SSL and TLS: SSL (Secure Sockets Layer) originated when the World Wide Web began to see new applications, such as online shopping and sending payment information. Eventually, more security was needed, and the **TLS (Transport Layer Security)** protocol was introduced in 1999 with TLS 1.0.

- **SSL 2.0 and 3.0** are deprecated and considered insecure. They should never be used.
- **TLS 1.0 and 1.1** were deprecated in 2021 due to known vulnerabilities. Major browsers no longer support them.
- **TLS 1.2** (2008) remains widely used and is considered secure when properly configured with modern cipher suites.
- **TLS 1.3** (2018) is the current standard. It removes outdated cryptographic algorithms, reduces handshake latency, and provides forward secrecy by default.

Where TLS Fits in the Network Model: As a result, data will be presented in an encrypted format (ciphertext) instead of its original form.



Upgrading Protocols with TLS: An existing cleartext protocol can be upgraded to use encryption via TLS. The following table lists the protocols covered so far and their default ports before and after the encryption upgrade via TLS.

Protocol	Default Port	Secured Protocol	Default Port with TLS
HTTP	80	HTTPS	443
FTP	21	FTPS	990
SMTP	25	SMTPS	465
POP3	110	POP3S	995
IMAP	143	IMAPS	993

TLS is not limited to web and email protocols. DNS can also be secured using TLS. **DNS over TLS (DoT)** encrypts DNS queries by wrapping standard DNS traffic inside a TLS connection, typically on port 853. A related approach, **DNS over HTTPS (DoH)**, sends DNS queries as HTTPS requests on port 443. Both prevent eavesdropping on DNS lookups, which would otherwise reveal which websites a user is visiting.

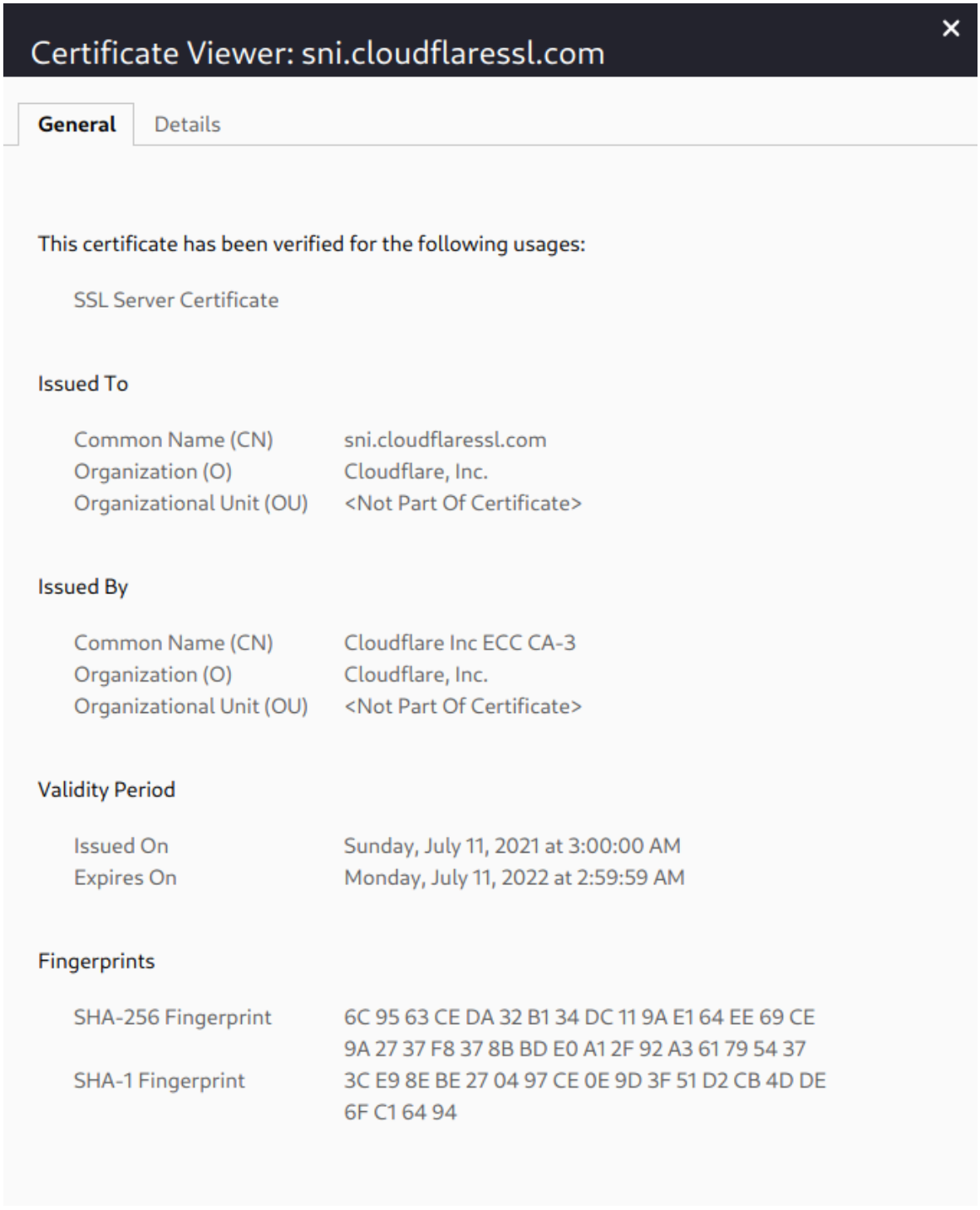
There are two approaches to adding TLS to a protocol:

Implicit TLS uses a dedicated port (as shown in the table above). The connection is encrypted from the start. When you connect to port 443 for HTTPS or port 993 for IMAPS, TLS negotiation begins immediately.

STARTTLS allows upgrading an existing cleartext connection to TLS on the same port. The client connects on the standard port (e.g., port 25 for SMTP), and then issues a `STARTTLS` command to upgrade the connection to TLS. This approach is common for email protocols. For SMTP, port 587 (submission) with STARTTLS is the recommended configuration for mail clients.

Both approaches provide encryption. However, implicit TLS is generally preferred because STARTTLS can be vulnerable to downgrade attacks if not properly implemented. An attacker performing a MITM attack could strip the `STARTTLS` command from the communication, forcing the connection to remain in cleartext.

Certificates and Trust: For TLS to be effective, especially when browsing the web over HTTPS, the system relies on public certificates signed by Certificate Authorities (CAs) trusted by your system



In the figure above, the following information is visible:

1. **To whom is the certificate issued?** This is the name of the company that will use this certificate.
2. **Who issued the certificate?** This is the certificate authority that issued this certificate.

3. **Validity period.** An expired certificate should not be trusted.

Your web browser handles this automatically, ensuring that you are talking with the correct server and that your communication is secure.

Answer the questions below

> DNS can also be secured using TLS. What is the three-letter acronym of the DNS protocol that uses TLS? DoT

13 - Secure Shell (SSH)

Secure Shell (SSH) was created to provide a secure way for remote system administration. It allows you to securely connect to another system over the network and execute commands on the remote system. The "S" in SSH stands for secure, which can be summarised as:

1. You can confirm the identity of the remote server.
2. Exchanged messages are encrypted and can only be decrypted by the intended recipient.
3. Both sides can detect any modification in the messages.

The above three points are ensured by cryptography. In more technical terms, they are part of confidentiality and integrity, made possible through the proper use of different encryption algorithms. SSH has become the universal standard for remote administration of servers, network devices, and cloud infrastructure. It completely replaced Telnet for interactive remote access due to its security guarantees.

SSH Authentication Methods: To use SSH, you need an SSH server and an SSH client.
The SSH server listens on port 22 by default. The SSH client can authenticate using several methods:

Password authentication is the simplest method. The user provides a username and password, which are transmitted over the encrypted SSH connection. While the password is protected in transit, this method is vulnerable to brute force attacks if weak passwords are used.

Public key authentication is the recommended method for regular use. You generate a key pair consisting of a private key (kept secret on your machine) and a public key (placed on servers you want to access). When connecting, the server challenges you to prove you possess the private key without actually transmitting it.

Certificate-based authentication is used in larger organisations. An SSH Certificate Authority signs user and host keys, eliminating the need to distribute public keys to every server. This scales better and allows for key expiration and revocation.

Multi-factor authentication (MFA) combines multiple methods. Many organisations now require both a key and a one-time password from an authenticator app.

Connecting via SSH: On Linux, macOS, and Windows 10/11, you can connect to an SSH server using the command `ssh username@MACHINE_IP`. This command tries to connect to the server at the specified IP address with the given login name. If an SSH server is listening on the default port, it will ask you to provide the password for that user (or use your key if configured). Once authenticated, you have access to the target server's terminal.

```
user@TryHackMe$ ssh mark@MACHINE_IP
mark@MACHINE_IP's password: XBtc49AB

The programs included with the Debian GNU/Linux system are free softwar
e;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.
```

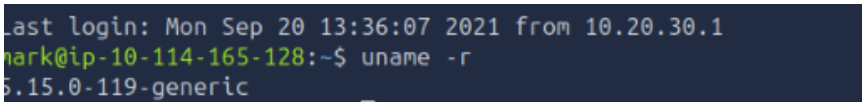
```
user@TryHackMe$ scp document.txt mark@MACHINE_IP:/home/mark
mark@MACHINE_IP's password:
document.txt                                          100% 1997KB  70.4M
B/s   00:00
```

SSH vs FTPS vs SFTP: It is worth clarifying the difference between these secure file transfer options:

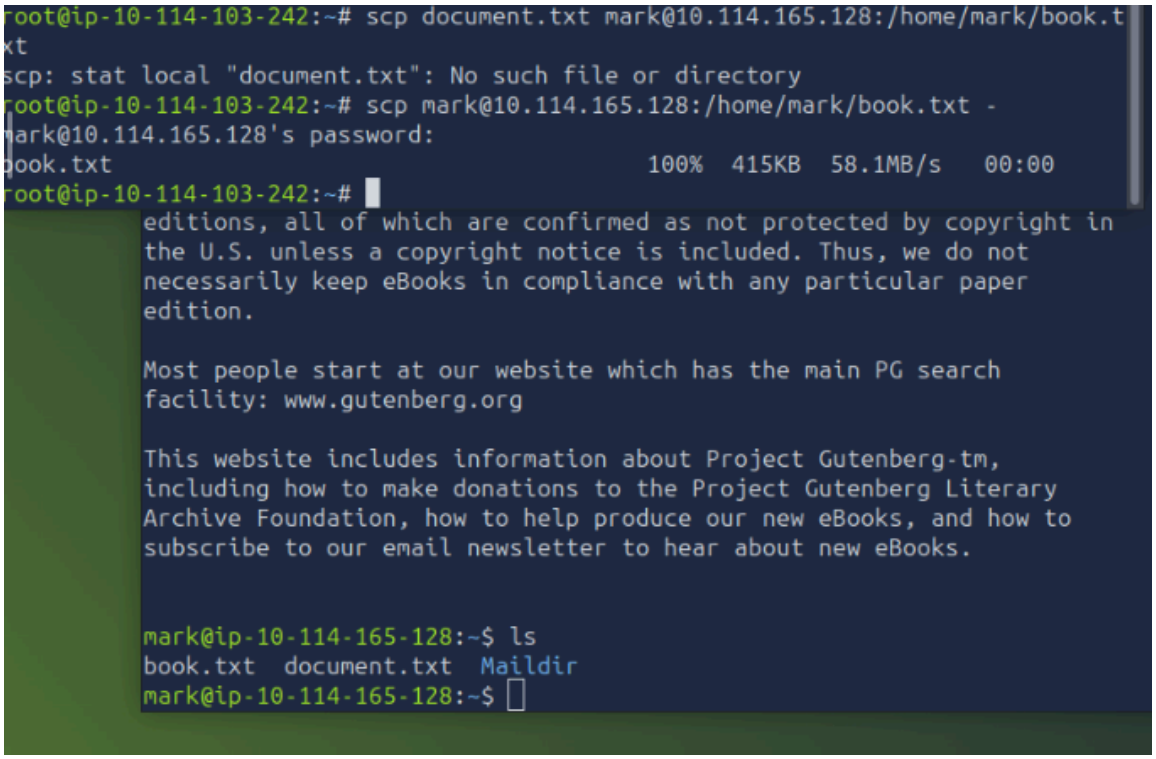
- **SFTP** runs over SSH (port 22) and is the most common choice for secure file transfers today.
- **FTPS** is FTP secured with TLS (port 990 for implicit TLS). It is a different protocol from SFTP despite the similar names.
- **SCP** also runs over SSH but is being phased out in favour of SFTP.

For most use cases, SFTP is the recommended choice because it uses the same authentication and encryption as SSH, simplifying management.

> Use SSH to connect to MACHINE_IP as mark with the password XBtc49AB. Using uname -r, find the Kernel release? 5.15.0-119-generic



> Use SSH to download the file book.txt from the remote system. How many KBs did scp display as download size? 415



14 - Password Attack

Many protocols require you to authenticate. **Authentication** is proving who you claim to be. When using protocols such as POP3, access to the mailbox should not be granted before verifying identity.

```
pentester@TryHackMe$ telnet MACHINE_IP 110
Trying MACHINE_IP...
Connected to MACHINE_IP.
Escape character is '^]'.
+OK MACHINE_IP Mail Server POP3 Wed, 15 Sep 2021 11:05:34 +0300
USER frank
+OK frank
PASS D2xc9CgD
+OK 1 messages (179) octets
STAT
+OK 1 179
LIST
+OK 1 messages (179) octets
1 179
.
```

Types of Password Attacks: Attacks against passwords have evolved beyond simple brute force:

Password Guessing requires some knowledge of the target, such as their pet's name, birth year, favourite sports team, or children's names. Social media makes gathering this information easier than ever.

Dictionary Attack attempts common words from a dictionary or wordlist. This is effective because many users choose real words or simple variations.

Brute Force Attack tries all possible character combinations. This is exhaustive and time-consuming, but effective against short passwords. The search space grows exponentially with password length, which is why longer passwords are significantly more secure.

Credential Stuffing uses username/password pairs leaked from previous breaches and tries them against other services. This exploits password reuse and is extremely effective. Attackers use automated tools to test millions of credentials across many sites simultaneously.

Password Spraying tries a small number of commonly used passwords against many accounts. Instead of trying many passwords against one account (which triggers lockouts), an attacker tries one or two passwords against thousands of accounts. This evades account lockout mechanisms.

Hybrid Attacks combine dictionary words with common patterns. For example, trying `Summer` with years appended (`Summer2023`, `Summer2024`) or common substitutions (`P@ssw0rd`, `Adm1n!`).

Wordlists and Breach Data: Over time, security researchers and attackers have compiled extensive wordlists containing leaked passwords from data breaches. One classic example is RockYou's list of breached passwords, which you can find on the AttackBox at `/usr/share/wordlists/rockyou.txt`.

Modern wordlists go far beyond RockYou:

- **SecLists** is a collection of multiple wordlists for different purposes, available at `/usr/share/seclists/` on many security distributions.
- **CrackStation** provides wordlists optimised for password cracking.
- **Breach compilations** contain billions of real passwords from various data breaches.

The choice of wordlist should depend on your knowledge of the target. A French user might use French words. A company's employees might use the company name with years or seasons. Custom wordlists tailored to the target are often more effective than generic ones.

THC Hydra: THC Hydra is a fast and flexible password cracking tool that supports many protocols, including FTP, POP3, IMAP, SMTP, SSH, and all methods related to HTTP. It provides an automated way to try common passwords or entries from a wordlist against network services.

```
hydra -l username -P wordlist.txt server service
```

Where the following options are specified:

- `l username`: The login name of the target.
- `P wordlist.txt`: A text file containing passwords to try.
- `server`: The hostname or IP address of the target server.
- `service`: The service you are attacking (e.g., `ftp`, `ssh`, `imap`, `pop3`, `smtp`).

Useful Hydra Options:

Option	Description
-l username	Single username to attack
-L users.txt	File containing a list of usernames
-p password	Single password to try
-P wordlist.txt	File containing a list of passwords
-s PORT	Specify a non-default port
-V or -vV	Verbose output showing attempts
-t n	Number of parallel connections (threads)
-d	Debug mode for troubleshooting
-f	Stop after the first valid password found
-w n	Wait time between connections

Other Password Attack Tools

While Hydra is excellent for network service attacks, other tools serve different purposes:

1. **Medusa** is similar to Hydra but with a modular design. Some find it more stable for certain protocols.
2. **Ncrack** is developed by the Nmap project and designed for high-speed parallel authentication testing.
3. **CrackMapExec (CME) / NetExec** specialises in Windows/Active Directory environments and can spray passwords across SMB, WinRM, LDAP, and other protocols.
4. **Burp Suite Intruder** is useful for Hydra attacking web-based login forms where 's HTTP modules may not work correctly.
5. **Hashcat and John the Ripper** are used for cracking password hashes offline rather than attacking live services. If you obtain password hashes (from a database breach, for example), these tools can recover the plaintext passwords much faster than attacking a live service.

Mitigating Password Attacks: Mitigation against password attacks depends on the target system. Modern defences include:

Password Policies enforce minimum complexity constraints. Modern guidance such as **NIST SP 800-63B** (a U.S. government standard for digital identity guidelines) recommends focusing on password length over complexity rules, blocking known compromised passwords, and not requiring regular password changes unless there is evidence of compromise.

Account Lockout temporarily or permanently locks an account after a certain number of failed attempts. This is effective against brute force but can be bypassed by password spraying or abused for denial of service.

Throttling and Rate Limiting delay responses to login attempts. A few seconds of delay is tolerable for legitimate users but severely hinders automated tools. More sophisticated implementations use exponential backoff.

CAPTCHA requires solving a challenge difficult for machines. Modern CAPTCHAs use behavioural analysis and risk scoring rather than just image recognition.

Multi-Factor Authentication (MFA) requires additional verification beyond the password, such as a code from an authenticator app, SMS (though SMS is less secure), or a hardware security key. MFA is one of the most effective defences against password attacks.

Passwordless Authentication eliminates passwords entirely using methods like:

- **Passkeys** (FIDO2/WebAuthn) use cryptographic keys stored on devices, replacing passwords with biometric or PIN verification.
- **Magic links** sent via email.
- **Hardware security keys** like YubiKeys.

Breached Password Detection checks passwords against known breach databases during registration and login. Services like "Have I Been Pwned" provide APIs for this purpose.

Behavioural Analysis detects anomalies such as login attempts from unusual locations, impossible travel scenarios, or patterns consistent with automated attacks.

IP-based Controls including geofencing, blocking known malicious IPs, and requiring additional verification for new devices or locations.

Using a combination of the above approaches provides defence in depth against password attacks. For high-security environments, moving towards passwordless authentication eliminates many of these attack vectors entirely.

> We learned that one of the email accounts is lazie. What is the password used to access the IMAP service on MACHINE_IP? butterfly

15 - Key Takeaways

- Use HTTPS instead of HTTP.
- Use SSH instead of Telnet.
- Use SFTP or FTPS instead of FTP.
- Use IMAPS/POP3S/SMTPS instead of their cleartext counterparts.

Protocol and Port Reference

Protocol	TCP Port	Application(s)	Data Security
FTP	21	File Transfer	Cleartext
FTPS	990	File Transfer	Encrypted (implicit TLS)
HTTP	80	Worldwide Web	Cleartext
HTTPS	443	Worldwide Web	Encrypted (implicit TLS)
IMAP	143	Email (MDA)	Cleartext
IMAPS	993	Email (MDA)	Encrypted (implicit TLS)
POP3	110	Email (MDA)	Cleartext
POP3S	995	Email (MDA)	Encrypted (implicit TLS)
SFTP	22	File Transfer	Encrypted (SSH)
SMTP	25	Email (MTA)	Cleartext
SMTP Submission	587	Email (MTA, client submission)	STARTTLS*
SMTPS	465	Email (MTA)	Encrypted (implicit TLS)
SSH	22	Remote Access and File Transfer	Encrypted
Telnet	23	Remote Access	Cleartext

Hydra Quick Reference

Hydra remains a very efficient tool for password attacks against network services. Its main options are summarised in the following table.

Option	Explanation
`-l username`	Provide a single login name
`-L users.txt`	Provide a file containing usernames
`-p password`	Provide a single password to try
`-P wordlist.txt`	Specify the password list to use
`server service`	Set the server address and service to attack
`-s PORT`	Use in case of non-default service port number
`-V` or `-vV`	Show the username and password combinations being tried
`-t n`	Number of parallel connections (threads)

Option	Explanation
`-w n`	Wait time between connections in seconds
`-f`	Stop after the first valid credential found
`-d`	Display debugging output if verbose output is not helping

Additional Tools to Explore

Beyond Hydra, consider learning these tools that complement what this room covered:

Tool	Purpose
Wireshark / tcpdump	Network packet capture and analysis
Bettercap	MITM attacks, ARP spoofing, and network reconnaissance
mitmproxy	Interactive HTTPS proxy for inspecting and modifying traffic
testssl.sh	Testing TLS/SSL configuration and vulnerabilities
Nmap	Port scanning, service detection, and scripting
CrackMapExec / NetExec	Password spraying and lateral movement in Windows environments
Hashcat / John the Ripper	Offline password hash cracking
Burp Suite	Web application security testing

Defensive Checklist: When assessing or securing systems, verify the following:

1. All services use TLS 1.2 or TLS 1.3 with strong cipher suites.
2. Cleartext protocols (Telnet, FTP, HTTP) are disabled or restricted to isolated networks.
3. SSH uses key-based authentication with password authentication disabled.
4. Strong password policies are enforced with breached password detection.
5. Account lockout or rate limiting is implemented for all authentication endpoints.
6. Multi-factor authentication is enabled for sensitive systems.
7. Network segmentation limits the impact of sniffing attacks.
8. Certificate validation is properly implemented to prevent MITM attacks.
9. HSTS (HTTP Strict Transport Security) is enabled for web applications to prevent SSL stripping.
10. Logging and monitoring detect authentication anomalies.